

Incident Response Playbook Companion

FIG_000 · guide v1.0 · 2026 · open reference · 9 sections

by Swastik Sagar

The IR lifecycle expanded from theory into practice – what actually happens at each phase, and two full playbook templates (phishing, ransomware) you can adapt directly.

```
$ read section_01 --start
```

WHAT'S INSIDE

SECTION	TOPIC
1 – 3	The IR lifecycle, preparation, and identification/triage
4 – 6	Containment strategies, eradication/recovery, and lessons learned
7 – 9	Full playbook templates for phishing and ransomware, and reference

How to use this guide: read start to finish for the full lifecycle, or jump straight to Section 7 or 8 for a ready-to-adapt playbook template. Every diagram is numbered and referenced directly in the surrounding text.

Table of Contents

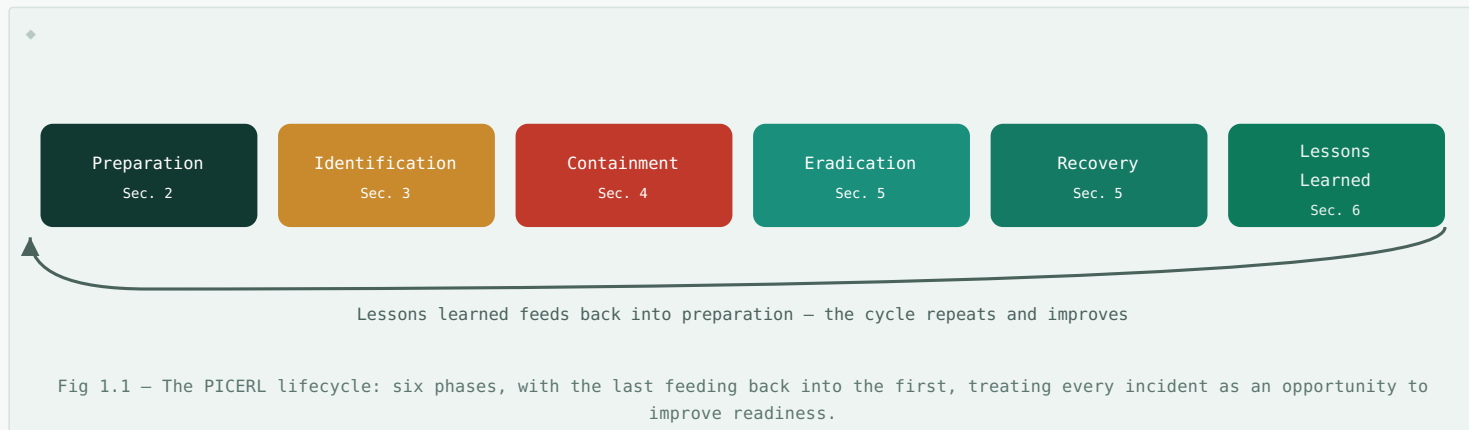
1. The IR Lifecycle	3
2. Preparation	4
3. Identification & Triage	5
4. Containment Strategies	6
5. Eradication & Recovery	7
6. Post-Incident: Lessons Learned	8
7. Playbook Template: Phishing	9
8. Playbook Template: Ransomware	10
9. Quick Reference & Glossary	11

This guide is designed to be read section by section, with diagrams positioned next to the concepts they illustrate.

The IR Lifecycle

1.1 A STRUCTURED RESPONSE, NOT IMPROVISATION

Incident response follows a well-established six-phase lifecycle (formalized by both NIST and SANS, with essentially identical substance), often remembered by the mnemonic **PICERL**: Preparation, Identification, Containment, Eradication, Recovery, Lessons Learned. Every phase in this guide's remaining sections corresponds directly to one of these six.



1.2 WHY THE ORDER MATTERS

Each phase depends on the previous one being done reasonably well – you can't effectively contain (Section 4) what you haven't properly identified (Section 3), and eradication (Section 5) attempted before containment risks the threat simply re-establishing itself elsewhere. Skipping or rushing a phase under pressure is one of the most common real-world IR mistakes, even among experienced teams.

1.3 THIS ISN'T PURELY LINEAR IN PRACTICE

Real incidents often loop back – identification frequently continues throughout containment as new information emerges, and containment actions sometimes reveal the need to revisit scope entirely. The lifecycle is a mental model and a checklist, not a rigid script that always proceeds in one direction without ever revisiting an earlier phase.

Preparation

2.1 THE PHASE THAT HAPPENS BEFORE ANYTHING GOES WRONG

Preparation is everything done in advance of an incident – and it's the single phase that most determines how well every subsequent phase goes. An incident discovered by a team with clear playbooks, defined roles, and tested tooling resolves dramatically faster and cleaner than the identical incident hitting an unprepared team improvising in real time.

2.2 WHAT PREPARATION ACTUALLY INCLUDES

- **Playbooks** – pre-written response procedures for common incident types (Sections 7–8 provide two full examples), so the team isn't inventing a response process from scratch during an active incident.
- **Defined roles & escalation paths** – who's the incident commander, who has authority to make containment decisions, who needs to be notified and when.
- **Tooling readiness** – a working, accessible SIEM (see the SIEM & Log Analysis guide), endpoint detection tooling, and forensic collection capability, verified functional *before* they're needed under pressure.
- **Logging & visibility baseline** – the Linux and Windows log sources covered in their respective guides need to actually be collecting and retained *before* an incident, since you can't retroactively generate historical logs that were never captured.
- **Communication plan** – templates and defined channels for internal updates, and if applicable, legal/regulatory/customer notification requirements.

Preparation is a continuous, ongoing investment, not a one-time checklist. Section 6's Lessons Learned phase specifically exists to feed newly discovered gaps back into preparation – the two phases form a genuine loop (Fig 1.1), not a start-and-forget setup step.

Identification & Triage

3.1 FROM ALERT TO CONFIRMED INCIDENT

Identification is determining whether something flagged by monitoring (a SIEM correlation rule, per the SIEM & Log Analysis guide) is actually a genuine security incident, and if so, understanding its scope – this is the same triage discipline covered operationally in the Linux for SOC Analysts and Windows Event Log Reference guides, now framed as the formal first active-response phase.

3.2 CORE TRIAGE QUESTIONS

QUESTION	WHY IT MATTERS
What actually happened?	Confirms this is a real incident, not a false positive (SIEM & Log Analysis guide, Section 7)
What's the scope – how many systems/accounts?	Determines containment strategy (Section 4) and required resources
When did it start?	Defines how far back log review and forensic collection need to reach
Is it still ongoing?	An active attacker changes urgency and containment approach dramatically versus a contained, historical event
What's the likely severity/impact?	Drives escalation path and communication urgency (Section 2.2)

3.3 BUILDING THE TIMELINE EARLY

Constructing a timeline of events – exactly the process demonstrated in the Windows Event Log Reference guide's Section 8 worked example – should begin during identification and continue to be refined throughout the rest of the response. An accurate, evolving timeline is often the single most valuable artifact for making good containment and eradication decisions later.

Resist the urge to fully resolve scope before acting. Waiting for a complete, perfect understanding of an incident's scope before taking any containment action at all often costs more than acting on a reasonable, good-enough understanding and refining it as more information comes in. Identification and containment (Section 4) frequently overlap in real practice, not strictly sequential.

Containment Strategies

4.1 STOP THE BLEEDING FIRST

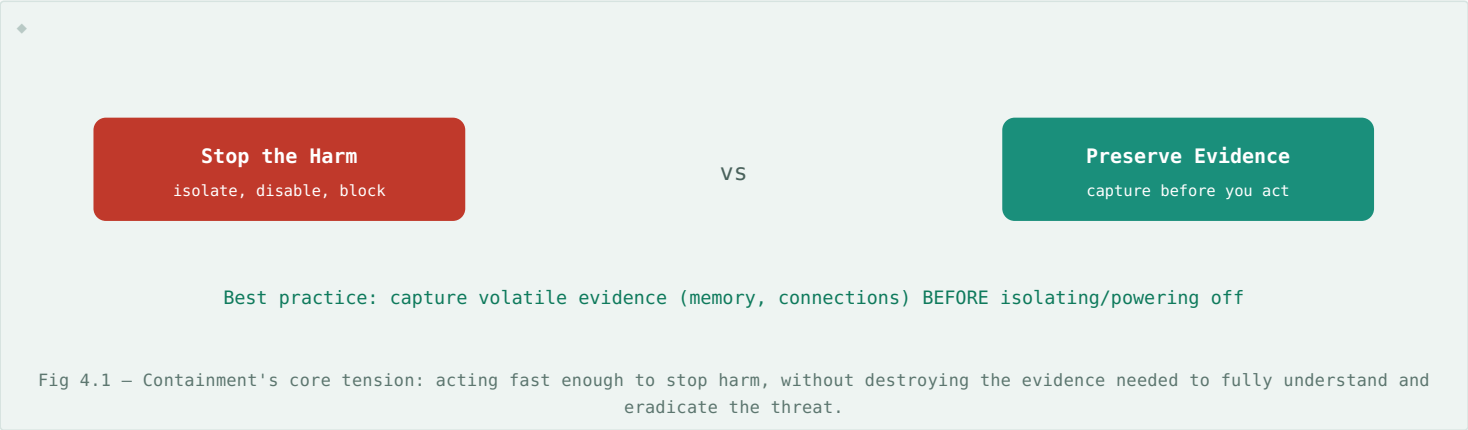
Containment limits an incident's ongoing damage without necessarily fully resolving it yet – the priority is stopping active harm (data exfiltration, lateral movement, further compromise) while preserving evidence needed for eradication (Section 5) and understanding the full scope from Section 3.

4.2 SHORT-TERM VS LONG-TERM CONTAINMENT

TYPE	APPROACH	TRADE-OFF
Short-term	Immediate isolation – disconnect a host from the network, disable a compromised account	Fast, stops the bleeding, but may not be sustainable or fully address the threat
Long-term	More deliberate measures – rebuilding from clean images, rotating all potentially exposed credentials	More thorough and sustainable, but takes longer to fully implement

4.3 THE EVIDENCE PRESERVATION TENSION

Containment actions can destroy forensic evidence if done carelessly – powering off a compromised host loses memory-resident evidence (running processes, network connections, exactly the kind of live data covered in the Linux for SOC Analysts guide, Section 6); simply deleting a malicious file removes a sample needed for later analysis (see the Malware Analysis Basics guide). Effective containment balances stopping harm against preserving what's needed to fully understand and later eradicate the threat.



Eradication & Recovery

5.1 ERADICATION: REMOVING THE THREAT COMPLETELY

Eradication removes the actual root cause identified during containment – malware, unauthorized accounts, persistence mechanisms (exactly the kind covered in the Linux for SOC Analysts guide, Section 7.2, and the Windows Event Log Reference guide's Section 5) – not just the immediately visible symptom. Incomplete eradication is one of the most common causes of an incident recurring shortly after being declared "resolved."

5.2 THE PERSISTENCE CHECKLIST APPLIES DIRECTLY HERE

Every persistence mechanism identified earlier in this guide's companion volumes needs explicit verification during eradication: cron jobs and SSH keys on Linux hosts, scheduled tasks and services on Windows hosts (Windows Event Log Reference guide, Section 5), and any newly created or modified accounts (Section 3 of that same guide). Missing even one persistence mechanism while removing the others often just delays, rather than prevents, the attacker regaining access.

5.3 RECOVERY: RETURNING TO NORMAL OPERATIONS

Recovery restores affected systems to normal, verified-clean operation – from clean backups or rebuilt images wherever feasible, rather than trusting a "cleaned" but previously-compromised system. Recovery includes not just restoring the systems themselves, but monitoring them closely afterward specifically for any sign the threat wasn't actually fully eradicated.

RECOVERY STEP	PURPOSE
Restore from known-clean backup/image	Avoids trusting a system that may still harbor undetected compromise
Rotate all potentially exposed credentials	Assumes any credential the attacker may have touched is burned
Enhanced monitoring post-recovery	Catches reinfection or missed persistence quickly if eradication was incomplete
Staged, verified return to production	Confirms stability before fully trusting the system with normal business load

Don't declare victory the moment systems are back online. The period immediately following recovery is exactly when incomplete eradication reveals itself – a spike in monitoring sensitivity for a defined period after recovery (not a quiet return to baseline monitoring) is standard, deliberate practice, not paranoia.

Post-Incident: Lessons Learned

6.1 THE PHASE MOST OFTEN SKIPPED UNDER PRESSURE

Once an incident is resolved, the team is often exhausted and eager to move on – but the **Lessons Learned** phase, done properly, is what actually improves the organization's readiness for next time (Section 1.3's feedback loop back into Section 2's preparation). Skipping it means every future incident starts from the same baseline of readiness as this one did.

6.2 THE POST-INCIDENT REVIEW

- **Full timeline reconstruction** – a final, complete version of the timeline built incrementally since Section 3, capturing exactly what happened and when.
- **What worked well** – genuinely useful to identify, not just as encouragement, but to make sure effective practices are retained rather than accidentally lost in future process changes.
- **What didn't work, or was missing** – gaps in detection, tooling, playbooks, or communication, identified honestly rather than defensively.
- **Concrete, assigned follow-up actions** – specific, owned improvements, not just a vague "we should do better next time" – feeding directly back into Section 2's preparation.

6.3 BLAMELESS REVIEW, DELIBERATELY

A review focused on assigning individual blame produces defensive, incomplete accounts of what actually happened – people naturally omit or soften details that might make them look bad. A **blameless** review culture, focused on identifying process and system gaps rather than individual fault, produces far more honest, useful input for actually improving preparation (Section 2) before the next incident.

This phase is where playbooks like Sections 7–8 actually get updated. A phishing or ransomware playbook that isn't periodically revised based on real incidents' lessons learned gradually drifts out of sync with how attacks and the environment actually evolve – the lifecycle's feedback loop (Fig 1.1) is what keeps playbooks like the following two sections genuinely current rather than static documents written once and never revisited.

Playbook Template: Phishing

A ready-to-adapt playbook, structured around the PICERL phases from Section 1.

7.1 IDENTIFICATION (SECTION 3)

- Confirm the report: obtain the original email with full headers, not just a forwarded/screenshotted copy.
- Check whether the link was clicked or attachment opened – determines whether this is a near-miss or an active compromise requiring full incident treatment.
- Search the mail system for the same sender/subject/link across other mailboxes – a single report is rarely the only recipient.

7.2 CONTAINMENT (SECTION 4)

- Block the sender domain/address and the malicious URL at the email gateway and web proxy.
- If a link was clicked: isolate the affected endpoint from the network (short-term containment, Section 4.2) pending further investigation.
- If credentials were entered on a phishing page: immediately disable/reset the affected account.

7.3 ERADICATION & RECOVERY (SECTION 5)

- Purge the phishing email from all mailboxes it reached, not just the original report.
- If a credential was compromised: rotate it, and check authentication logs (Event IDs 4624/4625, Windows Event Log Reference guide Section 2) for any suspicious logon using it before the reset.
- If malware was delivered via attachment: follow full endpoint eradication (Section 5.2's persistence checklist) rather than assuming email deletion alone resolves it.

7.4 LESSONS LEARNED (SECTION 6)

- \$ Was this phishing campaign targeted or broad?
- \$ Did email filtering catch it, or only user reporting?
- \$ Is targeted security awareness training needed for the affected team?

Playbook Template: Ransomware

A ready-to-adapt playbook for a significantly higher-severity incident type, again structured around Section 1's PICERL phases.

8.1 IDENTIFICATION (SECTION 3)

- Confirm actual encryption is occurring, not just a ransom note or false alarm – check for mass file modification events and unusual file extensions appearing.
- Determine scope urgently: how many hosts, is it actively spreading, has it reached backup systems.
- Identify the likely initial access vector if possible (phishing, exposed RDP, exploited vulnerability) – informs both containment scope and eradication.

8.2 CONTAINMENT (SECTION 4) – SPEED IS CRITICAL

- Immediately isolate affected hosts from the network – ransomware's active spread makes short-term containment (Section 4.2) urgent, even at the cost of some evidence preservation.
- Disable network shares and segment backup systems immediately if not already isolated – protecting backups is often the single highest-priority containment action.
- Disable or reset any accounts showing signs of compromise (Section 3 of the Windows Event Log Reference guide covers relevant privilege-escalation Event IDs to check).

8.3 ERADICATION & RECOVERY (SECTION 5)

- Do not pay the ransom as a first response – engage legal/leadership per the organization's predefined decision process (Section 2.2's communication plan should already define who makes this call).
- Rebuild affected systems from clean images rather than attempting in-place cleanup – ransomware's destructiveness makes "trust but verify" recovery (Section 5.3) especially critical here.
- Restore data from backups confirmed clean and unaffected – verify backup integrity before restoring, since some ransomware specifically targets backup systems.

8.4 LESSONS LEARNED (SECTION 6)

- \$ How did initial access actually occur – is that vector now closed?
- \$ Were backups sufficient, accessible, and fast enough to restore from?
- \$ How long from initial access to encryption – what detection opportunity was missed?

Ransomware compresses the entire lifecycle into far less time than most other incident types. The gap between identification and irreversible damage can be minutes, not hours – which is exactly why Section 2's preparation phase (tested playbooks, pre-defined decision authority, verified-working backups) matters disproportionately more here than for slower-moving incident types like Section 7's phishing scenario.

Quick Reference & Glossary

TERM	DEFINITION
PICERL	Preparation, Identification, Containment, Eradication, Recovery, Lessons Learned – the IR lifecycle.
Preparation	All readiness work done before an incident occurs – playbooks, roles, tooling, logging.
Identification	Confirming a genuine incident occurred and determining its scope.
Containment	Limiting an incident's ongoing damage without necessarily fully resolving it.
Short-Term Containment	Fast, immediate isolation actions to stop active harm.
Long-Term Containment	More deliberate, sustainable measures like credential rotation and rebuilding.
Eradication	Fully removing the root cause of an incident, not just visible symptoms.
Recovery	Restoring affected systems to normal, verified-clean operation.
Lessons Learned	Post-incident review feeding improvements back into preparation.
Blameless Review	A post-incident review culture focused on process gaps, not individual fault.
Incident Commander	The designated person with authority to make key decisions during a response.

End of guide. The two playbooks in Sections 7–8 are starting templates, not finished products – the real value of the PICERL lifecycle (Section 1) is that it gives you a checklist for adapting them, and for building entirely new playbooks for incident types not covered here, using the exact same six-phase structure every time.